Govern AI use at TTC, starting with CES AI Buddy

"Not mature enough for AI yet" is heard everywhere. Maturity starts with seeing what actually leaves. CES AI Buddy goes first; other TTC apps repoint to the same gateway.

What we want to solve

AI Buddy answers CES developer questions from our Roslyn code graph, source code and database schema, using a hosted model. It works. What we cannot do today is show what left, or who approved it.

- What is going out?
- The models are not on our enterprise framework. How safe is it?
- Does any of this satisfy the acts we must follow?

master.json: our Roslyn code graph (excerpt)

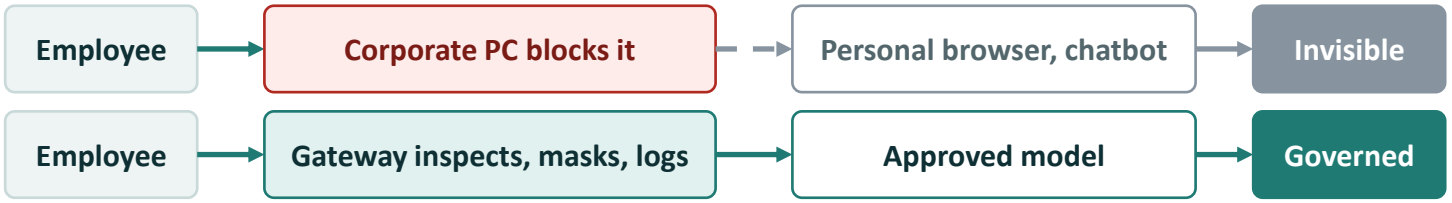
```
"Metadata": { "TargetFramework": "net8.0",
  "Statistics": { "NodeCount": 2904,
                  "EdgeCount": 4196 } },
"Nodes": [ {
  "Id": "class:global::BCES.Controllers
         .Admin.EmpSalaryController",
  "Type": "class",  "Project": "CES",
  "Location": {
    "Path": "Controllers\Admin\
             EmpSalaryController.cs",
    "StartLine": 31, "EndLine": 161 } } ],
"Edges": [ {
  "From": "route:/EmpSalary/CreateEmpSalary",
  "Type": "routes_to",
  "To": "method:...EmpSalaryController
         .CreateEmpSalary(...)" } ]
```

2,904 nodes, 4,196 edges. The graph holds structure only. The code itself is read from source and sent with the question. That is what needs governing.

Others publish principles; few can show enforcement

Who	What was found
Morgan Stanley	98% of adviser teams adopted its internal assistant; document access rose from 20% to 80%. Self-reported.
Ontario public sector	Copilot Chat was the only approved tool, yet about 6% of GenAI use. No control stopped sensitive uploads.
Canadian banks	Published principles, training and review; little on enforcement. OSFI E-23 applies from 1 May 2027.
TTC	Microsoft Copilot is the only approved AI tool (City of Toronto generative AI guidance).

A ban hides the risk. A gateway contains it.



Limits we state up front

- Findings rest on public, partly self-reported sources. We treat them as hypotheses to test.
- Masking will not catch everything. A name buried in a paragraph can get through. We report misses.
- Evidence is not compliance. Privacy assessments, contracts and legal review stay separate.
- Self-hosted models may fall short on capability. We compare on the same tasks.

Each sector answers to

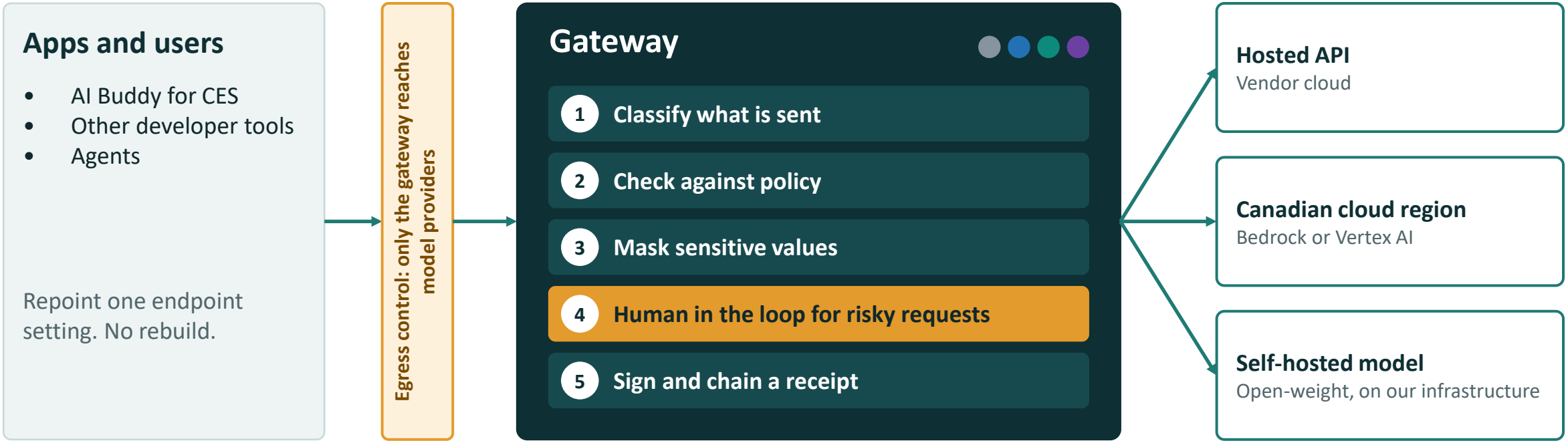
Canadian banks
OSFI E-23, B-13, B-10

Ontario public sector
Bill 194, Responsible Use of AI Directive, FIPPA

Federal government
TBS Directive on Automated Decision-Making, Privacy Act

City of Toronto
Generative AI Guidance, MFIPPA

Control egress: one gateway, a human in the loop



Start in log-only mode: see what leaves before enforcing anything.

Signed receipt per request: data class, decision, approver, time, payload or hash. Chained, so tampering shows. Verifiable offline.
Same need as ITSG-33 AU-9 and AU-10: audit records that cannot be altered unnoticed, and proof of who did what.

Benefits

- **See what leaves**
  Real evidence of what is sent, before any enforcement
- **Keep the use, stop the leak**
  Mask and approve instead of ban
- **Proof an auditor can check**
  Verify the receipt chain offline
- **Any model, same controls**
  Hosted, Canadian region or self-hosted

How a request flows, with a human in the loop

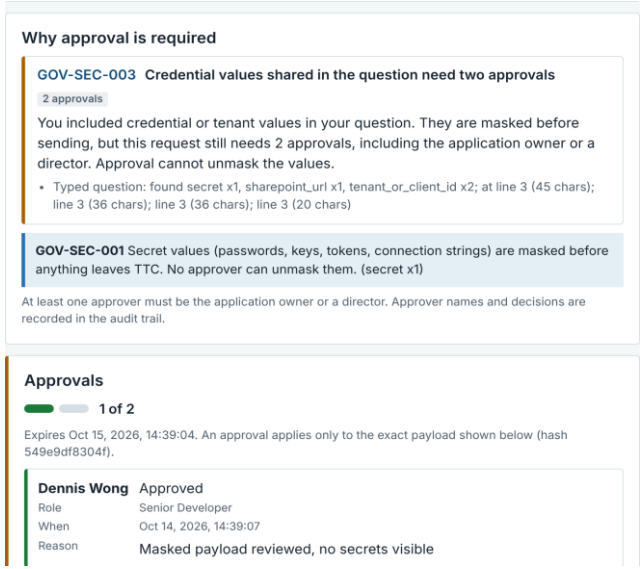


What it did with three of our test questions

Explain CES design	Allowed. Labour-rate and cost logic cut to signatures automatically. No approval.
Add SharePoint upload; tenant IDs and secret pasted	4 values masked. 2 approvals, one from the application owner or a director.
Why does the salary grid fail to save?	Labour-rate logic: 1 approval, or send signatures only.

Test data and policies are synthetic. Credentials shown are fake.

The approver's screen



Approve a 12-week proof of concept on real code and TTC infrastructure

Weeks 1 to 2	Weeks 3 to 6	Weeks 7 to 10	Weeks 11 to 12

- **Set up** Install the gateway on TTC infrastructure. Set the egress rule at the firewall so direct provider access is closed.
- **Log-only baseline** Route every call, enforce nothing, and report what actually leaves.
- **Enforce and compare** Policy, masking, human-in-the-loop approval. Compare hosted, Canadian-region and self-hosted models.
- **Report** Evidence pack and go or no-go recommendation.

Scope: AI Buddy for CES on the real code graph, source and schema. Legal and privacy review before any real prompt leaves TTC.

Decisions requested

1. Approve a time-boxed 12-week POC
2. Name a sponsor and a lead architect for weekly checkpoints
3. Nominate reviewers from IT, security, privacy and records
4. Approve the egress rule at the firewall and the model options to test

At week 12 you receive

- A working gateway on TTC infrastructure
- A receipt chain an auditor can verify offline
- Measured results across hosted, regional and self-hosted models
- A go or no-go recommendation